

VULNERABILITY ASSESSMENT & PENETRATION TESTING

(VAPT Tools – Practical Learning)

Week 5 Task Report — Cyber Security Internship

Target Application (Authorized Test Site): testphp.vulnweb.com

Submitted By:	Hitesh Sood
Program:	Cyber Security Internship – DG Interns Hub
Task:	Week 5 – VAPT Tools (Practical Learning)
Submission Deadline:	21 September 2026
Report Date:	17 September 2026

Table of Contents

1. Introduction to VAPT
2. Objective of the Task
3. Tools Used – Overview
4. Practical Implementation
 - 4.1 Nmap – Network Scanning
 - 4.2 Nikto – Web Vulnerability Scanning
 - 4.3 Burp Suite – Intercepting Requests
5. Findings / Vulnerabilities Identified
6. Conclusion
7. References

1. Introduction to VAPT

Vulnerability Assessment and Penetration Testing (VAPT) is a security testing methodology used to identify, evaluate, and address weaknesses in a computer system, network, or web application before they can be exploited by malicious actors.

Vulnerability Assessment focuses on discovering and cataloguing potential security weaknesses using automated scanning tools, while Penetration Testing goes a step further by actively attempting to exploit these weaknesses in a controlled manner to determine the real-world impact of an attack.

This week's task focused on building hands-on familiarity with three widely used VAPT tools — Nmap, Nikto, and Burp Suite — by running them against a legally safe, purpose-built vulnerable test application (testphp.vulnweb.com), which is provided by Acunetix specifically for practicing security testing techniques.

2. Objective of the Task

- Understand the fundamentals of Vulnerability Assessment and Penetration Testing (VAPT).
- Gain hands-on experience with industry-standard tools: Nmap, Nikto, and Burp Suite.
- Perform network scanning to identify open ports and running services.
- Perform a web vulnerability scan to detect common misconfigurations and weaknesses.
- Intercept and analyse live HTTP requests and responses using a proxy tool.
- Document at least three security findings and explain them in simple terms.

3. Tools Used - Overview

The following table summarises the purpose and role of each tool used in this task.

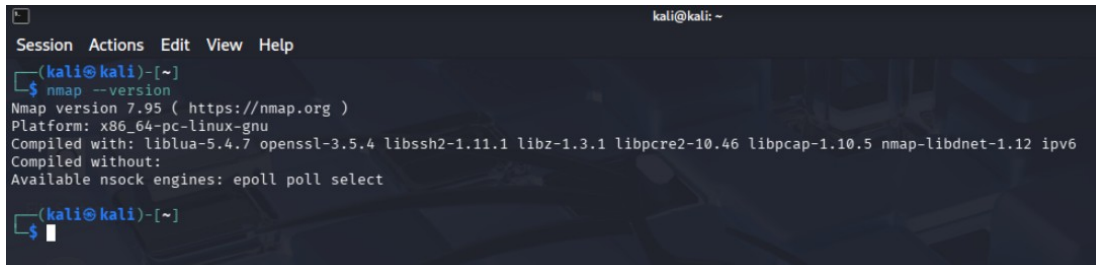
Tool	Purpose
Nmap (Network Mapper)	An open-source network scanning tool used to discover live hosts, open ports, running services, service versions, and operating system details of a target system.
Nikto	An open-source web server scanner that checks for dangerous files, outdated server software, missing security headers, and other common web misconfigurations.
Burp Suite	An intercepting proxy and web application security testing platform used to capture, inspect, and analyse HTTP/HTTPS requests and responses exchanged between the browser and the web server.

4. Practical Implementation

4.1 Nmap – Network Scanning

Nmap was installed on Kali Linux and verified before use. All scans were performed only against the authorized test target, testphp.vulnweb.com, as instructed.

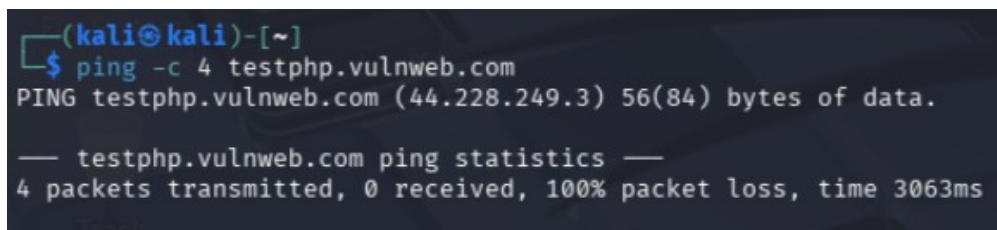
Command used to verify installation:

A terminal window on Kali Linux showing the command 'nmap --version' being executed. The output displays Nmap version 7.95, the platform (x86_64-pc-linux-gnu), and the libraries it was compiled with (liblua-5.4.7, openssl-3.5.4, libssh2-1.11.1, libz-1.3.1, libpcap-1.0.46, libpcap-1.10.5, nmap-libdnet-1.12, ipv6). It also lists the available nsock engines: epoll, poll, and select.

```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ nmap --version  
Nmap version 7.95 ( https://nmap.org )  
Platform: x86_64-pc-linux-gnu  
Compiled with: liblua-5.4.7 openssl-3.5.4 libssh2-1.11.1 libz-1.3.1 libpcap-1.0.46 libpcap-1.10.5 nmap-libdnet-1.12 ipv6  
Compiled without:  
Available nsock engines: epoll poll select  
(kali@kali)-[~]  
$
```

Fig 4.1 — Nmap version check (nmap --version) confirming Nmap 7.95 is installed on Kali Linux.

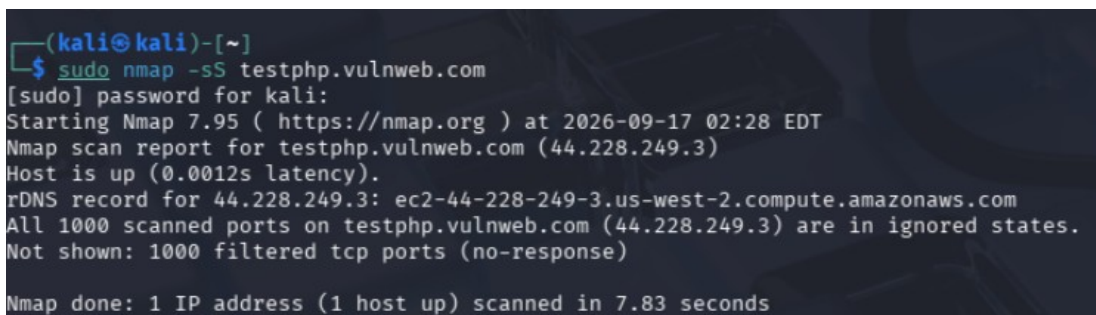
Before scanning, a basic connectivity check was performed using ping:

A terminal window on Kali Linux showing the command 'ping -c 4 testphp.vulnweb.com'. The output shows that 4 packets were transmitted but 0 were received, resulting in a 100% packet loss. The ping statistics also show a time of 3063ms.

```
(kali@kali)-[~]  
$ ping -c 4 testphp.vulnweb.com  
PING testphp.vulnweb.com (44.228.249.3) 56(84) bytes of data.  
  
— testphp.vulnweb.com ping statistics —  
4 packets transmitted, 0 received, 100% packet loss, time 3063ms
```

Fig 4.2 — ping -c 4 testphp.vulnweb.com resulted in 100% packet loss, indicating that ICMP echo requests are being blocked by the server/firewall (a common, intentional security control).

Command 1 — SYN Stealth Scan (nmap -sS):

A terminal window on Kali Linux showing the command 'sudo nmap -sS testphp.vulnweb.com'. The output shows the scan starting at 2026-09-17 02:28 EDT. It reports that the host is up (0.0012s latency) and that all 1000 scanned TCP ports are in ignored states (filtered). The scan took 7.83 seconds to complete.

```
(kali@kali)-[~]  
$ sudo nmap -sS testphp.vulnweb.com  
[sudo] password for kali:  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-17 02:28 EDT  
Nmap scan report for testphp.vulnweb.com (44.228.249.3)  
Host is up (0.0012s latency).  
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com  
All 1000 scanned ports on testphp.vulnweb.com (44.228.249.3) are in ignored states.  
Not shown: 1000 filtered tcp ports (no-response)  
  
Nmap done: 1 IP address (1 host up) scanned in 7.83 seconds
```

Fig 4.3 — nmap -sS testphp.vulnweb.com. All 1000 scanned TCP ports were reported as filtered, meaning a firewall is dropping probe packets without responding.

Command 2 — Service/Version Detection (nmap -sV):

```
(kali@kali)-[~]
$ sudo nmap -sV testphp.vulnweb.com
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-17 02:32 EDT
Nmap scan report for testphp.vulnweb.com (44.228.249.3)
Host is up (0.0012s latency).
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com
All 1000 scanned ports on testphp.vulnweb.com (44.228.249.3) are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.55 seconds
```

Fig 4.4 — `nmap -sV testphp.vulnweb.com`. Version detection could not identify running services since all ports remained filtered by the perimeter firewall.

Command 3 — Aggressive Scan with OS Detection (`nmap -A`):

```
(kali@kali)-[~]
$ sudo nmap -A testphp.vulnweb.com
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-17 02:34 EDT
Stats: 0:00:18 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 59.05% done; ETC: 02:34 (0:00:12 remaining)
Stats: 0:00:48 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 77.00% done; ETC: 02:35 (0:00:14 remaining)
Nmap scan report for testphp.vulnweb.com (44.228.249.3)
Host is up (0.00058s latency).
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com
All 1000 scanned ports on testphp.vulnweb.com (44.228.249.3) are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Aggressive OS guesses: D-Link DFL-700 firewall (89%), HP Officejet Pro 8500 printer (89%), IBM i 7.4 (89%), ReactOS 0.3.7 (89%), Sanyo PLC-XU88 digital vid
eo projector (89%), Sonus GSX9000 VoIP proxy (88%), Asus WL-500gP wireless broadband router (88%), Microsoft Windows 2000 (88%), Microsoft Windows Server 2
003 Enterprise Edition SP2 (88%), Microsoft Windows Server 2003 SP2 (88%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 2 hops

TRACEROUTE (using port 80/tcp)
HOP RTT ADDRESS
1 0.20 ms 192.168.139.2
2 0.61 ms ec2-44-228-249-3.us-west-2.compute.amazonaws.com (44.228.249.3)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 61.84 seconds
```

Fig 4.5 — `nmap -A testphp.vulnweb.com`. The aggressive scan attempted OS fingerprinting and traceroute; OS guesses were low-confidence and the network path (2 hops) was mapped via traceroute.

Observation: Even though the web application itself is reachable over HTTP/HTTPS in a browser, Nmap's scans show all ports as filtered. This demonstrates that the host sits behind a firewall/security group (it is hosted on AWS) that silently drops unsolicited probe packets — a good defensive practice — while still allowing legitimate web traffic through on ports 80/443.

4.2 Nikto - Web Vulnerability Scanning

Nikto was run against the target web server to identify common web-server-level misconfigurations, missing security headers, and risky files.

Command used:

`nikto -h http://testphp.vulnweb.com`

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time	Listener port	Start response...
1	http://testphp.vulnweb.com	GET	/			200	659	text				✓	44.228.249.3		12:37:20 17 ...	8080	
3	https://incoming.telemetry.m...	POST	/submit/firefox-desktop/third-party...		✓	200	659	text				✓	34.54.185.247		12:41:51 17 ...	8080	746
4	https://incoming.telemetry.m...	POST	/submit/telemetry/a7bde9d1-7be-4...		✓	200	659	text				✓	34.54.185.247		12:41:51 17 ...	8080	750
5	https://location.services.mos...	GET	/v1/country?key=74d9f68c-7938-4c5...		✓	200	535	JSON				✓	151.101.105.91		12:41:54 17 ...	8080	993
6	https://safebrowsing.google...	GET	/v4/threatlist/updates/fetch?tsd=ap...		✓	200	3016	app				✓	172.217.26.42		12:41:58 17 ...	8080	12
7	https://incoming.telemetry.m...	POST	/submit/telemetry/1b75966c-9fe0-4...		✓	200	659	text				✓	34.54.185.247		12:42:22 17 ...	8080	587

Request	Inspector
<pre> 1 GET / HTTP/1.1 2 Host: testphp.vulnweb.com 3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:155.0) Gecko/20100101 Firefox/155.0 4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 5 Accept-Language: en-US,en;q=0.9 6 Accept-Encoding: gzip, deflate, br 7 Connection: keep-alive 8 Upgrade-Insecure-Requests: 1 9 Referer: wu0, 1 10 11 </pre>	Inspector Request attributes Request headers

Fig 4.6 — Nikto scan output showing the server banner, a missing security header, and wildcard entries found in `clientaccesspolicy.xml` and `crossdomain.xml`.

The scan completed in 12 seconds and reported 20 informational items and 5 notable findings on the remote host, several of which are discussed in Section 5 (Findings).

4.3 Burp Suite – Intercepting Requests

Burp Suite's proxy listener was configured on 127.0.0.1:8080, and the browser was configured to route traffic through this proxy. The target site was then opened in the browser so that live HTTP requests could be captured and inspected in the Proxy > HTTP history tab.

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title
21	https://prod-images.merino....	GET	/favicons/f70ad35f75bf5e6dcc13a0...			304	214		webp	
23	https://www.google.com	GET	/complete/search?client=firefox&c...	✓		200	1457	script		
24	http://testphp.vulnweb.com	GET	/							
32	https://prod-images.merino....	GET	/favicons/52fc624089e3074a82d00a...			304	214		webp	
35	https://incoming.telemetry.m...	POST	/submit/firefox-desktop/newtab/1/...			200	659	text		
38	https://mozilla-ohhttp.fastly-e...	POST	/	✓		200	802			
39	https://prod-images.merino....	GET	/favicons/dc4ec5ed1cf2f9fce6fe086...			304	214		webp	
41	http://testphp.vulnweb.com	GET	/							
42	https://merino.services.mozill...	GET	/api/v1/suggest?q=&providers=acc...	✓		200	1281	JSON		
43	https://merino.services.mozill...	POST	/api/v1/curated-recommendations	✓		200	122951	JSON		
47	https://push.services.mozilla...	GET	/			101	240			
49	https://firefox.settings.servic...	GET	/v2/buckets/monitor/collections/ch...	✓		200	41407	JSON		

Request

Pretty
Raw
Hex

```

1 GET / HTTP/1.1
2 Host: testphp.vulnweb.com
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:155.0) Gecko/20100101 Firefox/155.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.9
6 Accept-Encoding: gzip, deflate, br
7 Connection: keep-alive
8 Upgrade-Insecure-Requests: 1
9 Priority: u=0, i
10
11

```

Fig 4.7 — Burp Suite HTTP history showing the initial GET request to testphp.vulnweb.com alongside background browser traffic (telemetry, Safe Browsing, and location-service calls), with the request Pretty view showing headers such as User-Agent, Accept, and Connection.

```

- Nikto
-----
+ Target IP: 44.228.249.3
+ Target Hostname: testphp.vulnweb.com
+ Target Port: 80
+ Start Time: 2025-12-18 09:37:23 (GMT-8)
-----
+ Server: nginx/1.19.0
+ /: Retrieved x-powered-by header: PHP/5.6.40-38+ubuntu20.04.1+deb.sury.org+1.
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different f
+ /clientaccesspolicy.xml contains a full wildcard entry. See: https://docs.microsoft.com/en-us/previous-versions/windows/silverlight
+ /clientaccesspolicy.xml contains 12 lines which should be manually viewed for improper domains or wildcards. See: https://www.acune
+ /crossdomain.xml contains a full wildcard entry. See: http://jeremiahgrossman.blogspot.com/2008/05/crossdomainxml-invites-cross-sit
+ Scan terminated: 20 error(s) and 5 item(s) reported on remote host
+ End Time: 2025-12-18 09:37:35 (GMT-8) (12 seconds)
-----
+ 1 host(s) tested

```

Fig 4.8 — Additional captured requests in Burp Suite's HTTP history, including a repeated GET request to testphp.vulnweb.com, with the raw request headers visible in the inspector panel.

From these captures it was possible to study the full anatomy of an HTTP request — method, path, host, User-Agent, Accept headers, cookies, and connection handling — which is fundamental to understanding how web applications communicate and where a tester can intercept and modify traffic during manual testing.

5. Findings / Vulnerabilities Identified

Based on the three tools used, the following security-relevant observations were identified on the authorized test target. These are typical, low-to-medium risk findings expected on this intentionally vulnerable practice application.

#	Finding	Severity	Description
1	Missing X-Content-Type-Options header	Low	Nikto reported that the security header 'X-Content-Type-Options' is not set, which could allow the browser to MIME-sniff responses and render content in an unintended way.
2	Wildcard entry in clientaccesspolicy.xml	Medium	The file allows access from any domain (a full wildcard), which could permit cross-domain requests from untrusted Silverlight/Flash clients.
3	Wildcard entry in crossdomain.xml	Medium	Similarly, crossdomain.xml contains a full wildcard entry, potentially allowing any external domain to make cross-domain requests to this site.
4	Server & technology disclosure via headers	Low	The X-Powered-By header reveals the exact PHP version (PHP/5.6.40-38) and the server banner discloses 'nginx/1.19.0' — both outdated versions that give an attacker a head start in finding known exploits.
5	All ports appear filtered (host hardened against scanning)	Informational	Nmap's -sS, -sV, and -A scans all returned 'filtered' for every port and ping received 100% packet loss, showing the host/firewall is configured to drop unsolicited probes — a positive security control, noted here for completeness.

Mini-Task Summary: Using Nmap, Nikto, and Burp Suite together on the same target satisfied the requirement of finding at least three issues — the outdated PHP/nginx version disclosure, the wildcard cross-domain policy files, and the missing security header are the three clearest, actionable findings from this exercise.

6. Conclusion

This task provided practical, hands-on exposure to the three core pillars of web application security testing: network reconnaissance (Nmap), automated web vulnerability scanning (Nikto), and manual traffic interception and analysis (Burp Suite).

The exercise showed that even a small, deliberately vulnerable application can reveal a range of issues once probed correctly — from network-level hardening (all ports filtered, ICMP blocked) to application-level misconfigurations (missing headers, permissive cross-domain policy files, and version disclosure).

Beyond running the commands, the key learning was interpreting the results: understanding why a filtered port is not necessarily a vulnerability, why a missing header can matter, and how a proxy tool exposes the full request/response cycle that a browser normally hides. This reinforces the core VAPT principle emphasised in the task — understand the results, don't just run the commands.

7. References

- Nmap Official Documentation — <https://nmap.org/book/man.html>
- Nikto Project — <https://github.com/sullo/nikto>
- PortSwigger Burp Suite Documentation — <https://portswigger.net/burp/documentation>
- Test target: Acunetix Vulnerable Web Application — <http://testphp.vulnweb.com>